Argus SBOM Guard

gestione delle vulnerabilità a partire dagli SBOM

Cronaca di un side project

...chissà se avevamo davvero bisogno di un ennesimo tool open source?!

Matteo Vitali (trotto)

Who Am I

Backend Developer and DevOps



- **Sociologist by training** and passionate about computer science.
- **Gnu/Linux** user, free and **open source** software advocate.
- Develop in **Python** and **Django** is my favorite way to build things.
- **Python Marche** founder and co-organizer
  >> https://marche.python.it



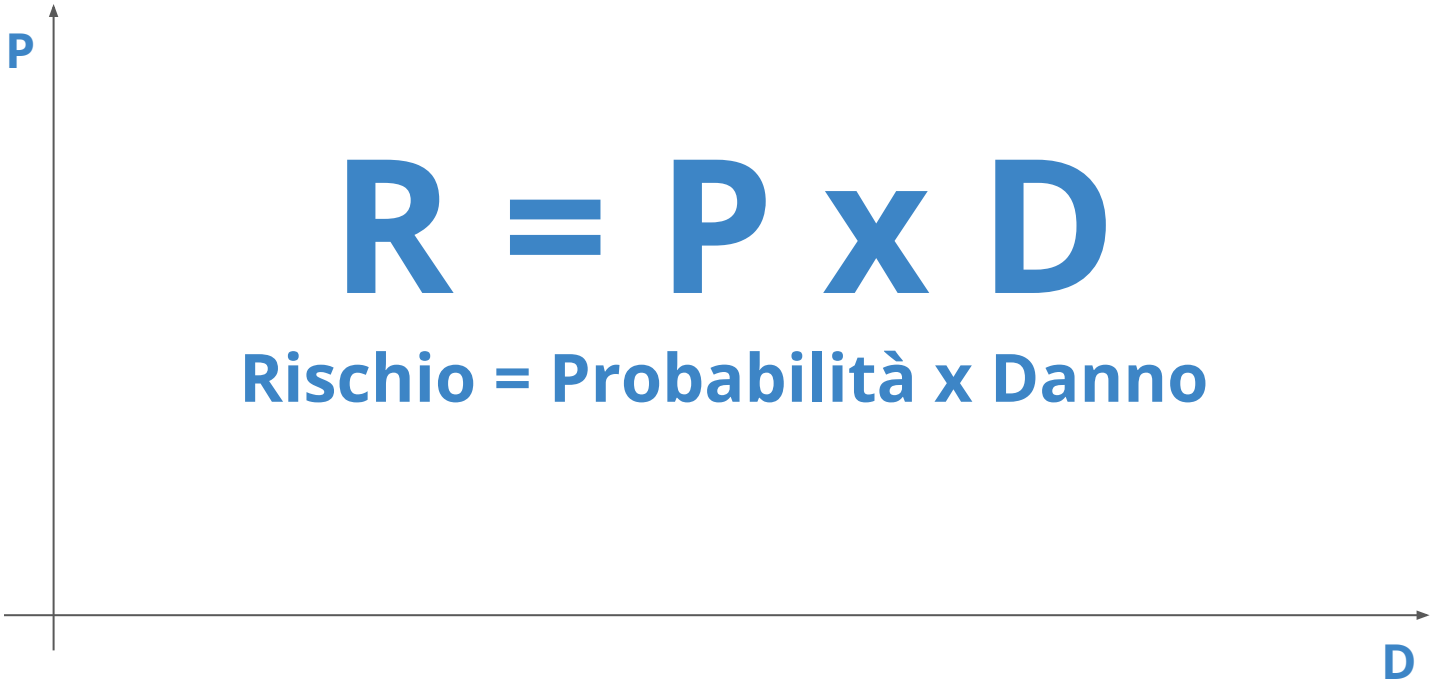
Agenda

1. Breve introduzione al Vulnerability Management
2. Make or Buy?... (or use an open source tool on premise?)
3. Argus SBOM Guard (panoramica)


RISK MANAGEMENT
IT'S A KIND OF A BIG DEAL

Risk Management

Come si definisce il rischio e come si 'cataloga'?



$$R = P \times D$$

Rischio = Probabilità x Danno

Risk Management & Vulnerability Management

Questa è la chiave di tutto…





Rapporto Clusit 2025

CLUSIT – Associazione Italiana per la Sicurezza Informatica (dati relativi al 2024)

75% del campione ha subito almeno un attacco nell'ultimo anno;

Una PMI viene colpita ogni 11 secondi;

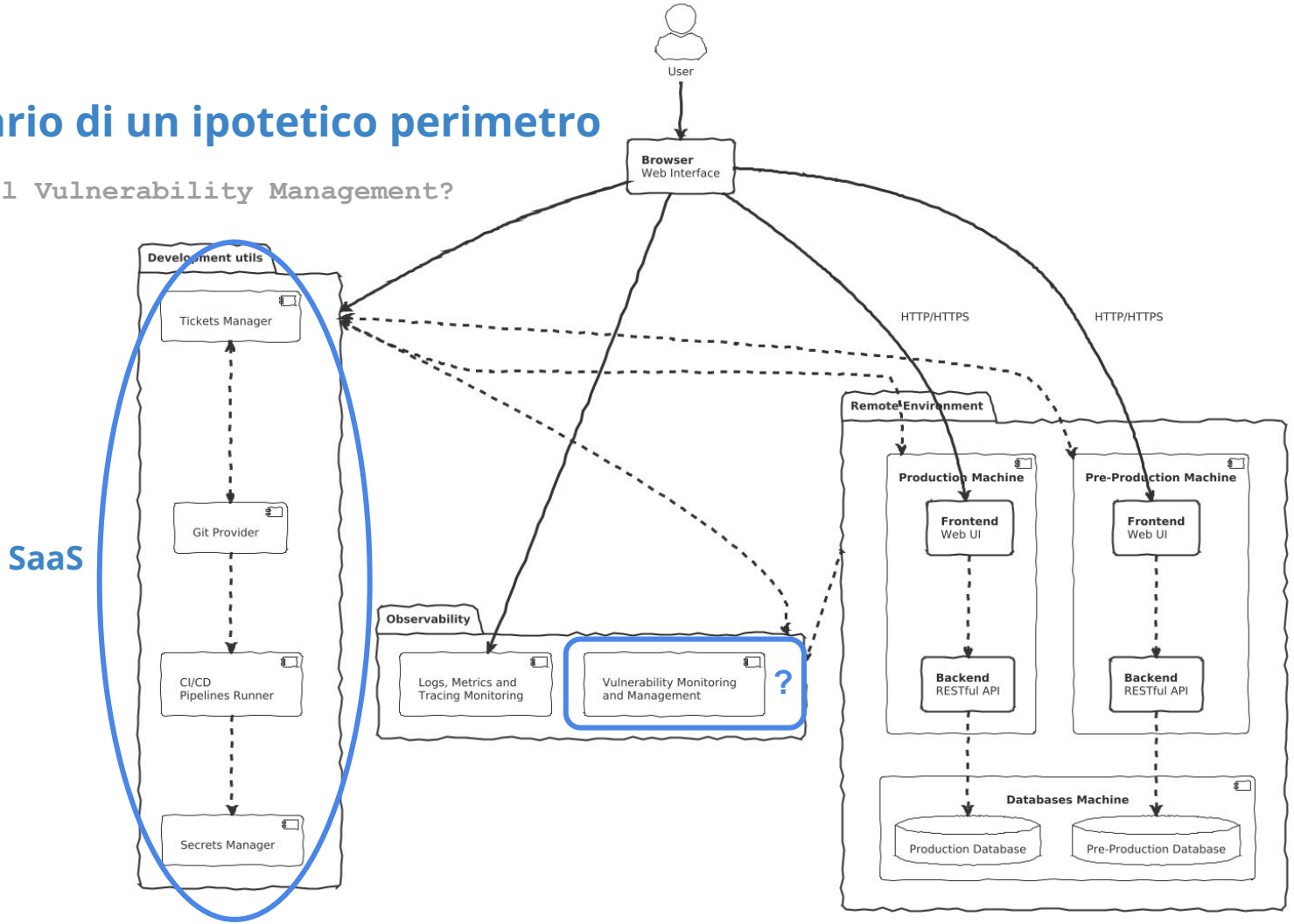
Il 60% chiude entro 6 mesi dall'attacco;

Il danno medio è pari a 59.000 euro.

https://clusit.it/pubblicazioni/

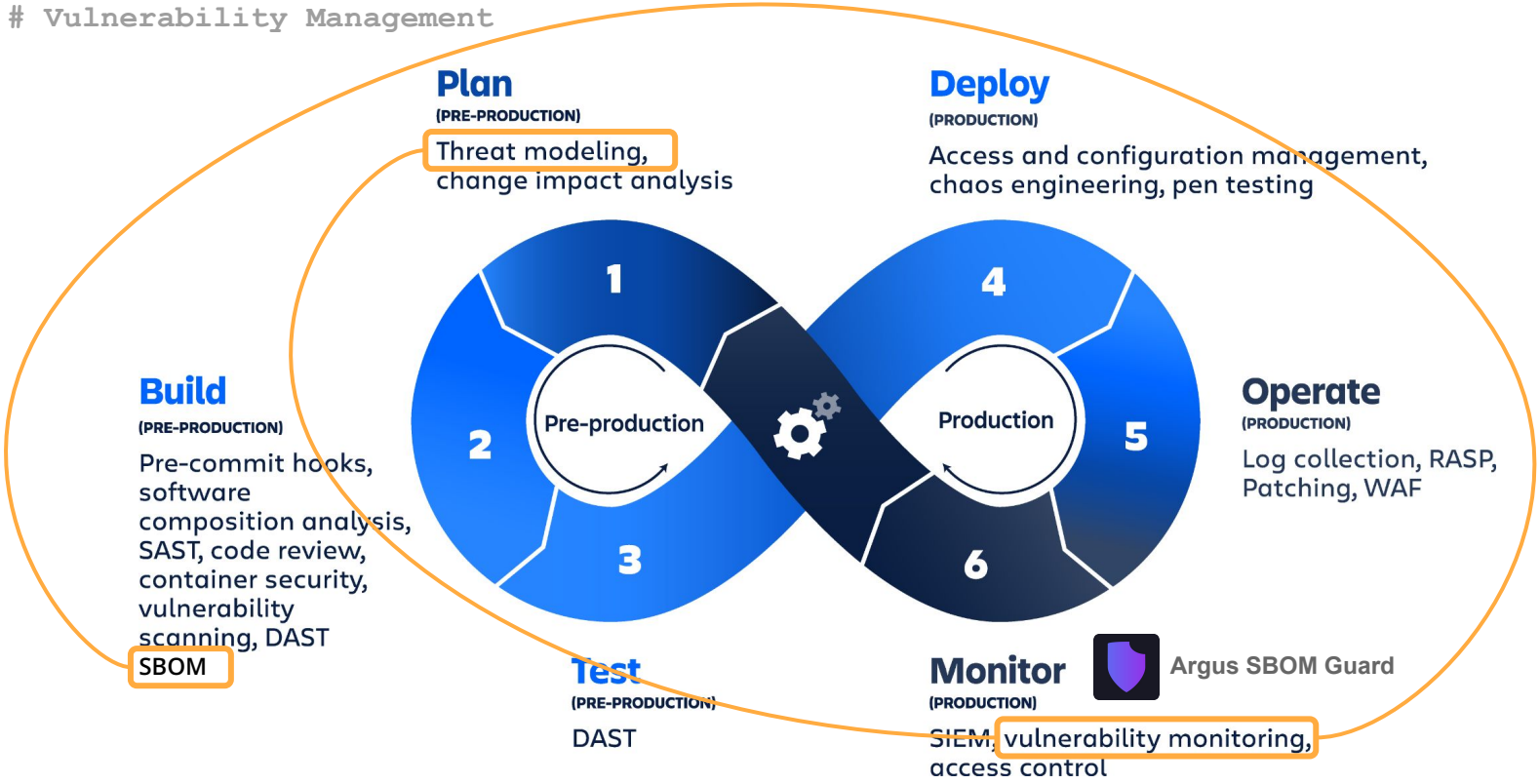
Scenario di un ipotetico perimetro

… e il Vulnerability Management?



SBOM & Vulnerability Management

```
# Vulnerability Management
```



SBOM (Software Bill Of Material)

```
# Definizione
```

Uno **SBOM** elenca tutti i componenti, le librerie e i moduli di un prodotto software in un **formato leggibile da una macchina**.

Questo **inventario** aiuta le organizzazioni a **tenere traccia degli elementi software**, identificare le vulnerabilità e mitigare i rischi di **sicurezza nella supply chain**.

SBOM (Software Bill Of Material)

Cosa contiene uno SBOM

- **Metadata:** autore, timestamp, componente principale
- **Fornitore del componente**: entità che produce/fornisce il componente
- **Nome del componente**: nome assegnato dal fornitore
- **Versione del componente**: versione specifica del componente
- **Identificatori univoci**: PURL, CPE, SWID
- **Hash crittografico**: verifica dell'integrità e identificazione dell'artefatto
- **Relazioni di dipendenza**: dipendenze dirette e transitive
- **Informazioni sulla licenza**: condizioni di utilizzo del componente

Formati e standard

- **SPDX** (Linux Foundation)
- **CycloneDX** (OWASP Foundation)
- **SWID tag** (ISO/IEC)

SBOM (Software Bill Of Material)

```
# Come generare uno SBOM
```

```
$ docker build --pull --tag registry.example.com/myproject/myapp:1.0 .

$ docker push registry.example.com/myproject/myapp:1.0

$ syft registry.example.com/myproject/myapp:1.0 \
    --output spdx-json=./sbom_spdx.json \
    --output cyclonedx-json=./sbom_cdx.json
```


build artifact
push artifact
Generate SBOM
And now ????
imgflip.com

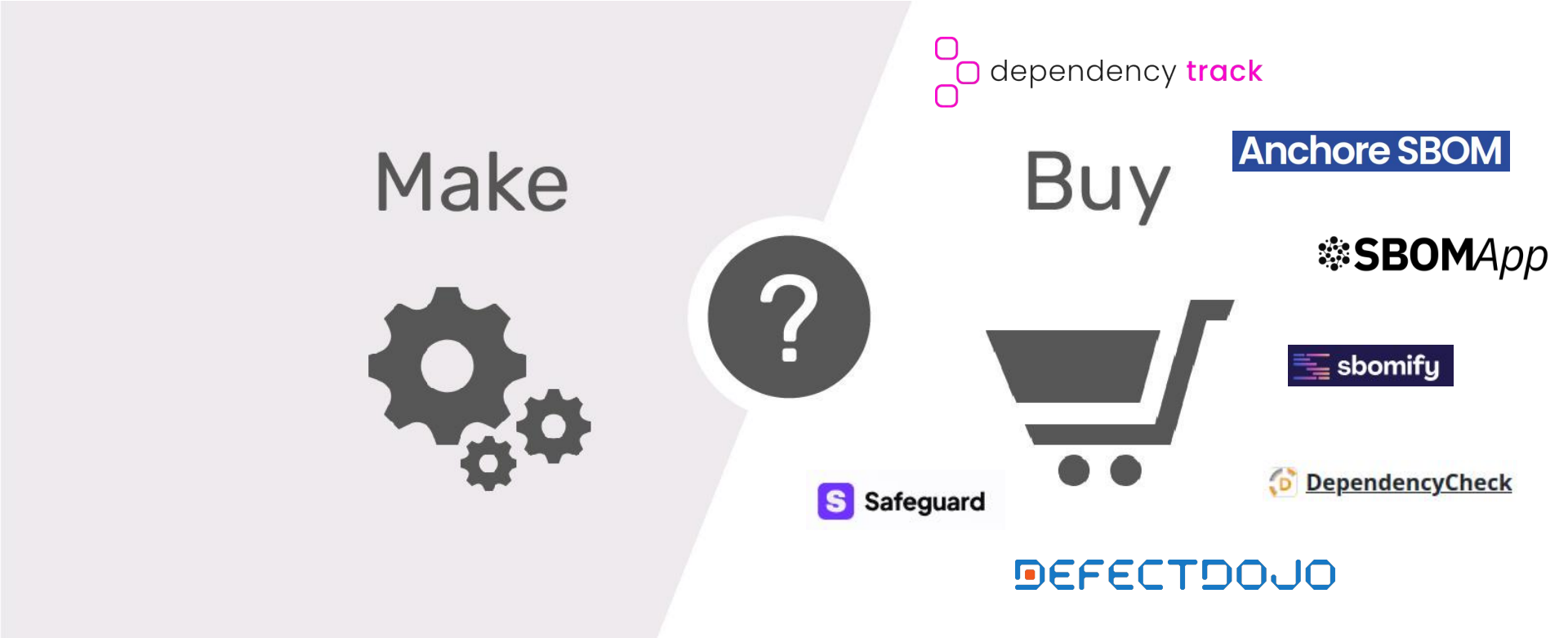
Risk Management & Vulnerability Management

Make or Buy?… or use an open source tool on premise?!



Risk Management & Vulnerability Management

Make or Buy?… or use an open source tool on premise?!



Risk Management & Vulnerability Management

```
# Make or Buy?… or use an open source tool on premise?!
```

Cosa stavo cercando…

SBOM ingestion centralizzato

gestire uno storico

correlare vulnerabilità

UI backoffice semplice e minimale

API e integrabile con una CI/CD

open source

Non volevo…

reinventare un generatore di SBOM

costruire un altro database CVE

duplicare Grype/Trivy/OSV

una piattaforma monolitica

workflow manuali

una black box e vendor lock in

Risk Management & Vulnerability Management

Make or Buy?… or use an open source tool on premise?!

Argus SBOM Guard

Make





Buy



Argus SBOM Guard - Cronaca di un side project

`# …avevamo davvero bisogno di un ennesimo tool open source?!`



Argus SBOM Guard

release v1.0.0 | license AGPLv3 | tests passing | coverage 100%

openssf best practices passing

A centralized and Open Source SBOM vulnerability management platform.
Self-hostable on prem, deploy anywhere.

https://github.com/trottomv/argus-sbomguard/

Argus SBOM Guard - Cronaca di un side project

```
# Features
```

- **SBOM ingestion** — Upload and store **CycloneDX** & **SPDX** SBOMs
- **Vulnerability Scanning** — Automatic analysis via **Grype** and OSV API
- **Vulnerability Tracking** — CVE, open/fixed/wontfix reconciliation, **historical trends**
- **Supply Chain Visibility** — **Projects, services**, dependencies, version history
- **Integrations** — **REST API** and **gRPC** with key-based authentication
- **Dashboard** — **Real-time trends** and **per-project** vulnerability metrics
- **Alerting** — Slack, Discord and Email **notifications** for new vulnerabilities

https://github.com/trottomv/argus-sbomguard/

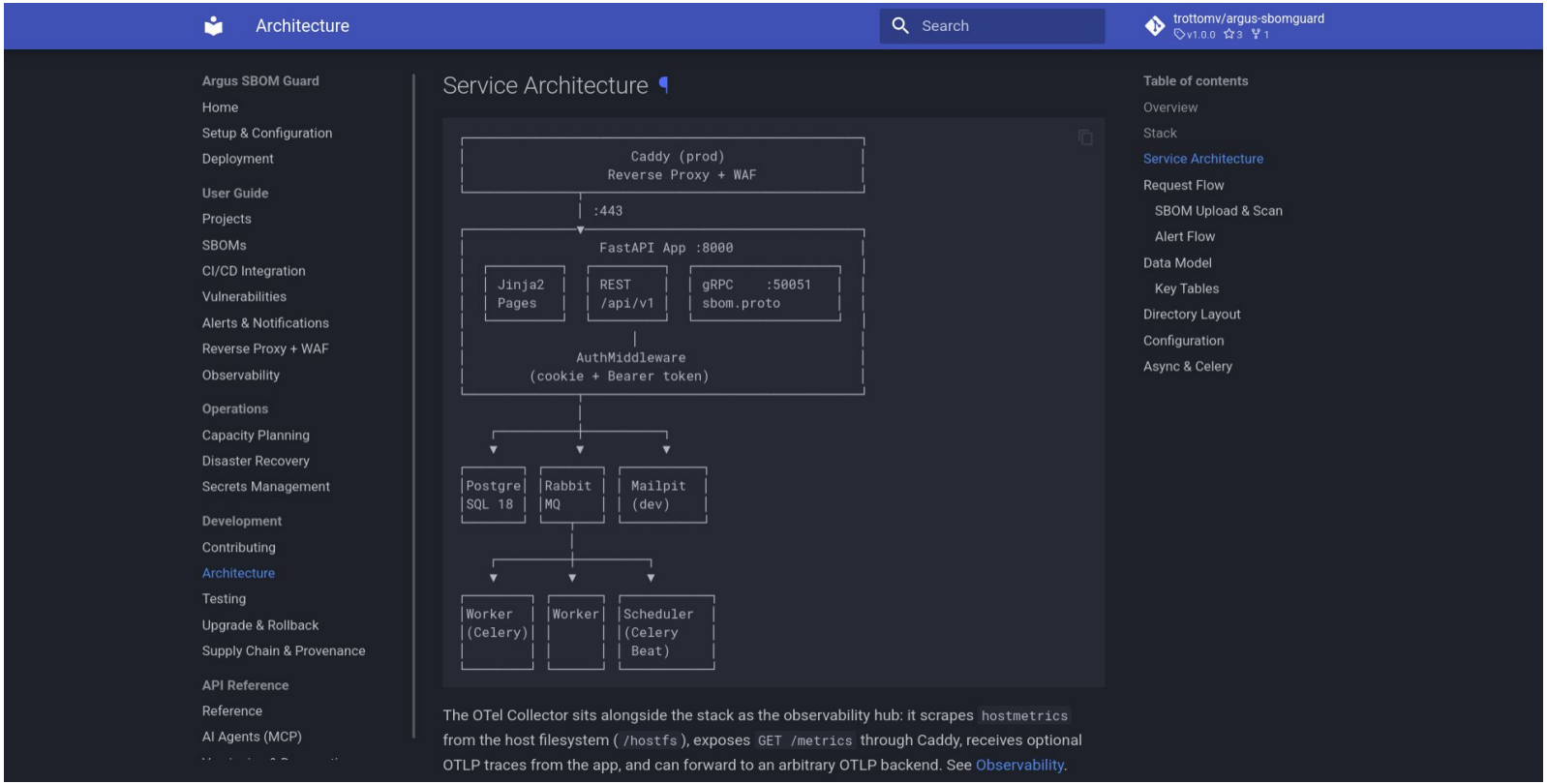
Argus SBOM Guard - Cronaca di un side project

```
# Who Is This For?
```

- **Platform / SRE teams** tracking dependencies across microservices
- **Security engineers** monitoring vulnerability exposure over time
- **DevSecOps teams** integrating SBOM management into CI/CD
- **Open source maintainers** generating and managing SBOMs
- **Compliance teams** that need SBOM history and audit trails

https://github.com/trottomv/argus-sbomguard/

Argus SBOM Guard - Cronaca di un side project



https://trottomv.github.io/argus-sbomguard/

Argus SBOM Guard - Cronaca di un side project

```
# Architettura
```

Component	Technology
Reverse proxy	**Caddy** + **WAF** OWASP Coraza + **certificato ssl** (Let's Encrypt)
Backend	**FastAPI** + **SQLAlchemy** (async) + **API** + **gRPC** + **Auth** (API KEY)
Broker + Worker	**RabbitMQ** + **Celery**
Database	**PostgreSQL** 18
Frontend	**Jinja2** + **HTMX** + Alpine.js + Tailwind CSS + **Auth** (passwordless via email, signed cookies)
Vuln scanner	**Grype** + OSV API
AI agents integration	**MCP server** (read only)
Observability	**OpenTelemetry Collector** (OTLP + hostmetrics)
Orchestration	**Docker Compose** (helm chart k8s in roadmap)

Argus SBOM Guard - Cronaca di un side project

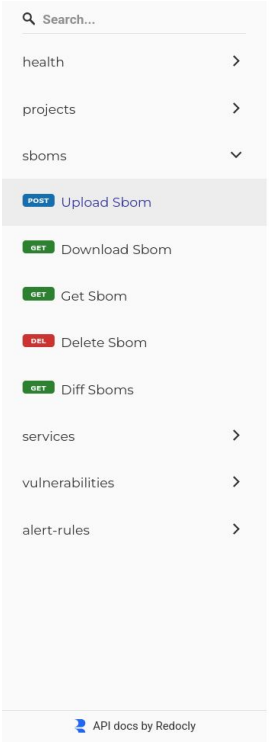
```
# Quick Start
```

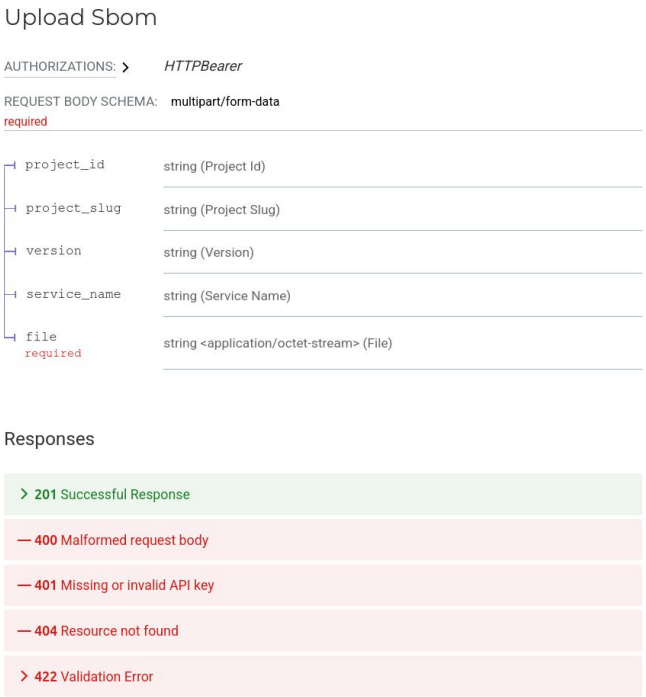
```
$ git clone git@github.com:trottomv/argus-sbomguard.git
$ cd argus-sbomguard
$ cp .env.example .env
$ docker compose up -d
```

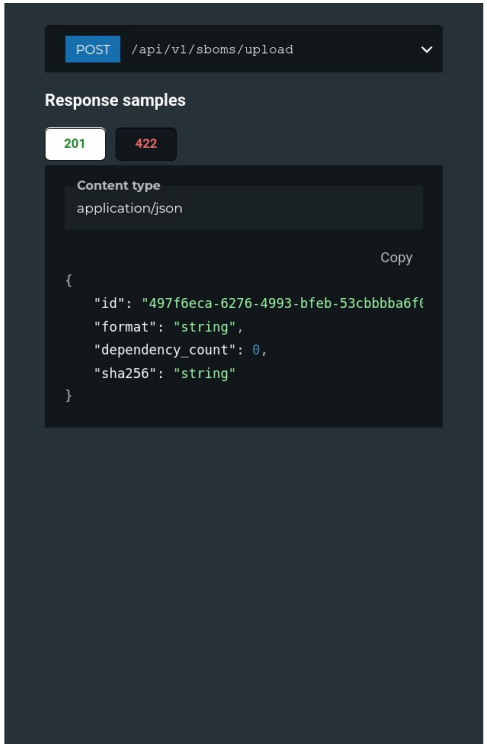
https://trottomv.github.io/argus-sbomguard/latest/setup

Argus SBOM Guard - Cronaca di un side project

```
# https://argus-sbomguard.local/api/docs
```







Argus SBOM Guard - Cronaca di un side project

```
# Upload SBOM
```

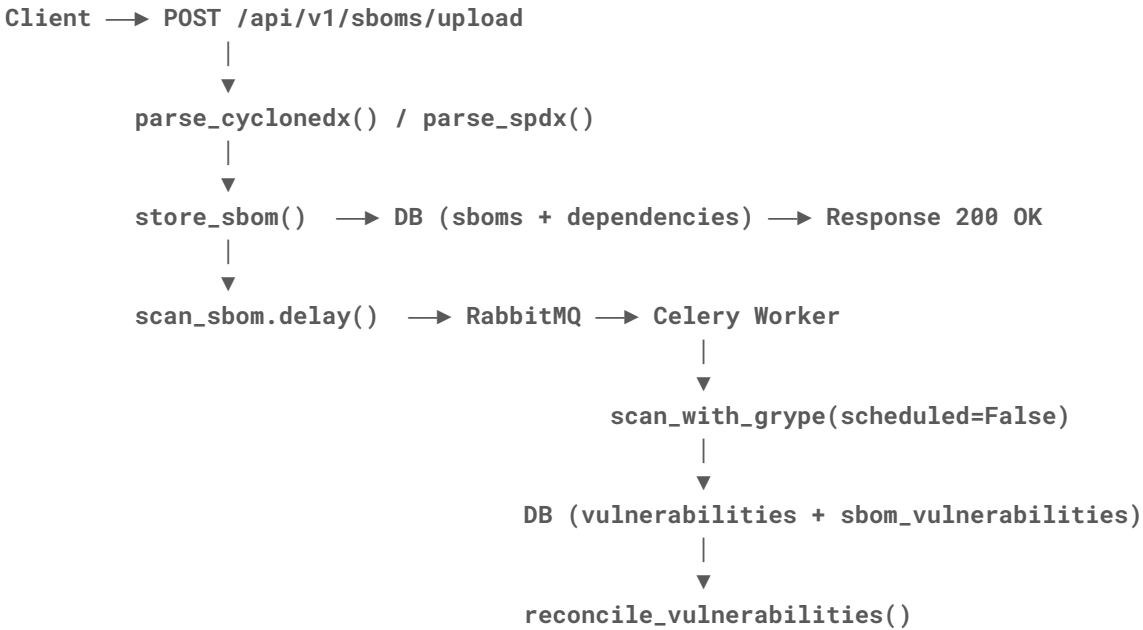



```
$ curl --fail -X POST "${ARGUS_URL}/api/v1/sboms/upload" \
    --header "Authorization: Bearer ${ARGUS_API_KEY}" \
    --form "project_slug=my-project" \
    --form "service_name=my app" \
    --form "version=1.2.3" \
    --form "file=@sbom.json"
```

https://trottomv.github.io/argus-sbomguard/latest/guide/ci/

Argus SBOM Guard - Cronaca di un side project

Request flow



Argus
SBOM Guard

- Dashboard
- Projects
- SBOMs
- Vulnerabilities
- Settings

v0.0.1-beta · AGPL v3

Dashboard

admin@argus.local

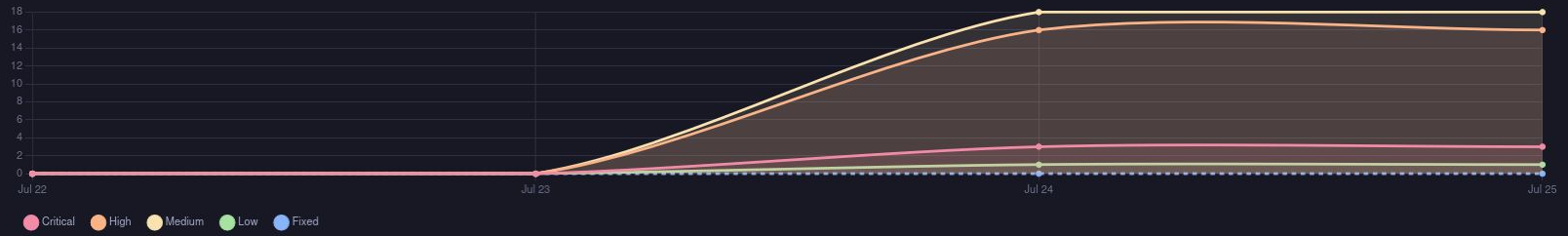
Dashboard

Overview of your SBOM landscape

+ New Project

PROJECTS	SBOMS	CRITICAL	HIGH
1	3	3	16

Vulnerability Trends (30 days)



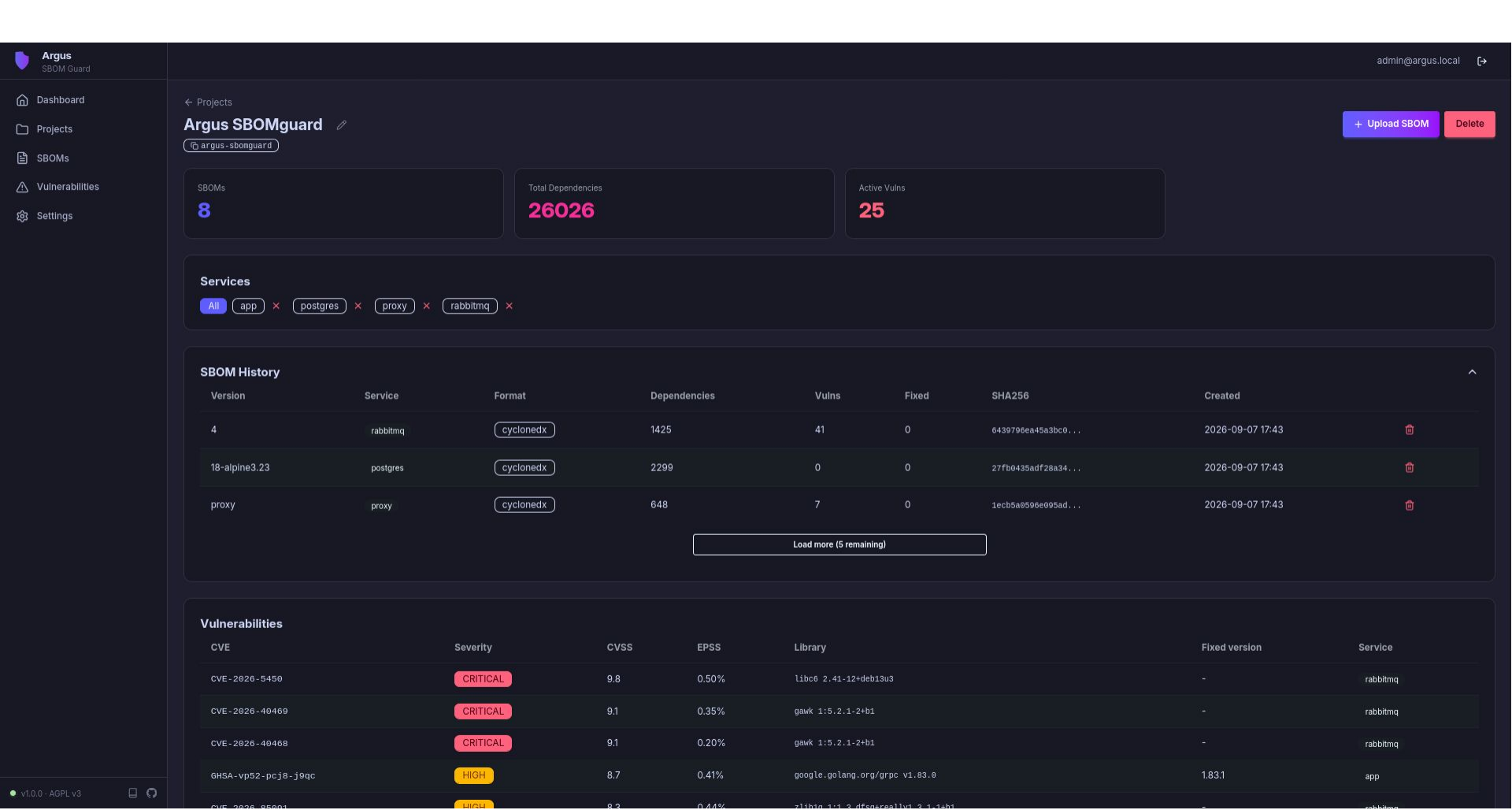
Vulnerability Overview

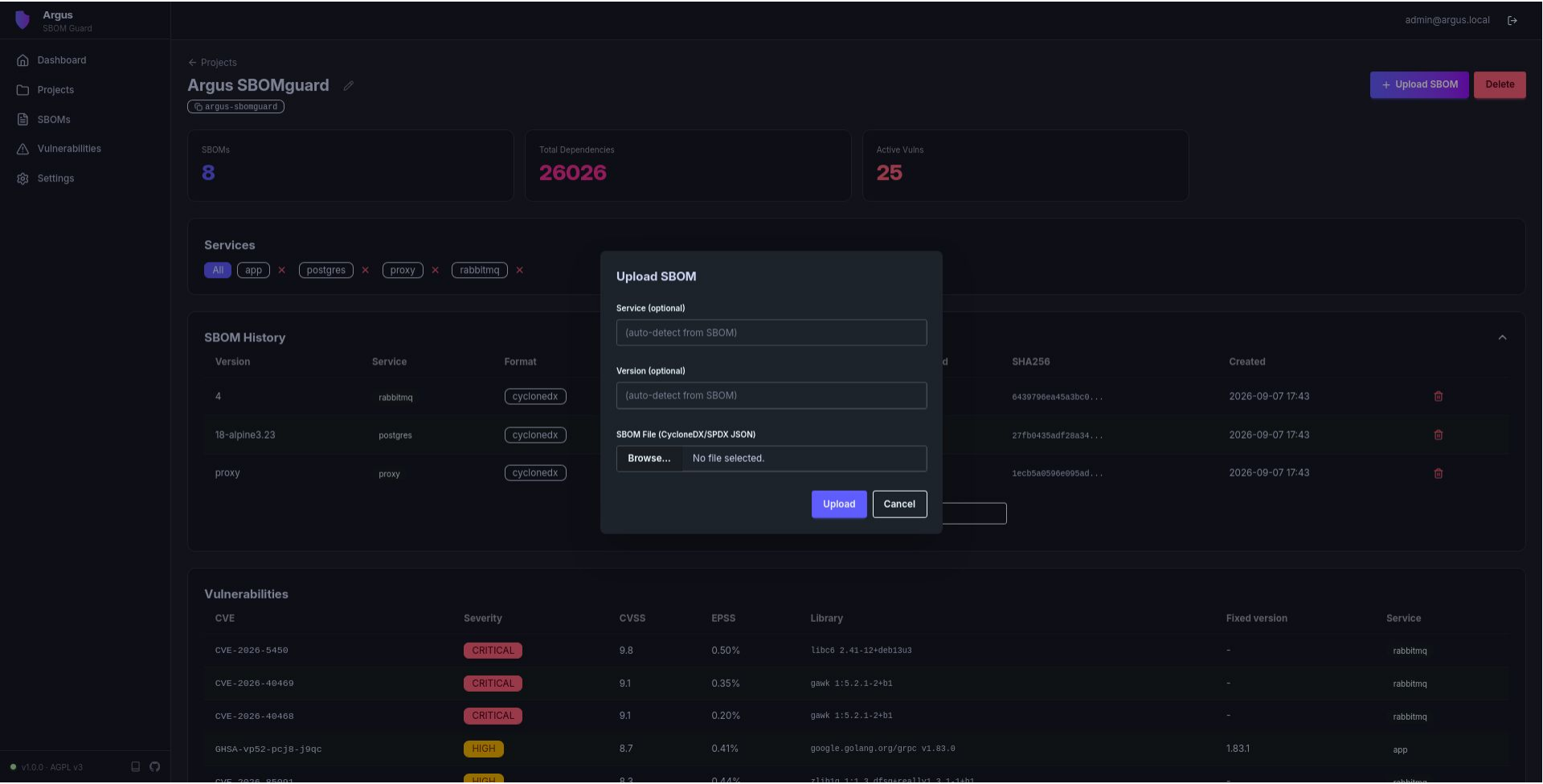
Critical	3
High	16
Medium	18
Low	1

FIXED
0

Recent SBOMs

PROJECT	SERVICE	VERSION	DEPS	DATE
argus-sbomguard	rabbitmq	4	1425	2026-07-24
argus-sbomguard	postgresql	18-alpine3.23	2041	2026-07-24
argus-sbomguard	app	development	7516	2026-07-24


Argus
SBOM Guard
admin@argus.local
Dashboard
Projects
SBOMs
Vulnerabilities
Settings
← Projects
Argus SBOMguard
argus-sbomguard
+ Upload SBOM
Delete
SBOMs
8
Total Dependencies
26026
Active Vulns
25
Services
All
app
postgres
proxy
rabbitmq
SBOM History
Version
Service
Format
Dependencies
Vulns
Fixed
SHA256
Created
4
rabbitmq
cyclonedx
1425
41
0
6439796ea45a3bc0...
2026-09-07 17:43
18-alpine3.23
postgres
cyclonedx
2299
0
0
27fb0435adf28a34...
2026-09-07 17:43
proxy
proxy
cyclonedx
648
7
0
1ecb5a0596e095ad...
2026-09-07 17:43
Load more (5 remaining)
Vulnerabilities
CVE
Severity
CVSS
EPSS
Library
Fixed version
Service
CVE-2026-5450
CRITICAL
9.8
0.50%
libc6 2.41-12+deb13u3
-
rabbitmq
CVE-2026-40469
CRITICAL
9.1
0.35%
gawk 1:5.2.1-2+b1
-
rabbitmq
CVE-2026-40468
CRITICAL
9.1
0.20%
gawk 1:5.2.1-2+b1
-
rabbitmq
GHSA-vp52-pcj8-j9qc
HIGH
8.7
0.41%
google.golang.org/grpc v1.83.0
1.83.1
app
v1.0.0 · AGPL v3


Argus
SBOM Guard
admin@argus.local
Dashboard
Projects
SBOMs
Vulnerabilities
Settings
← Projects
Argus SBOMguard
argus-sbomguard
+ Upload SBOM
Delete
SBOMs
8
Total Dependencies
26026
Active Vulns
25
Services
All
app
postgres
proxy
rabbitmq
SBOM History
Version
Service
Format
SHA256
Created
4
rabbitmq
cyclonedx
6439796ea45a3bc0...
2026-09-07 17:43
18-alpine3.23
postgres
cyclonedx
27fb0435adf28a34...
2026-09-07 17:43
proxy
proxy
cyclonedx
1ecb5a0596e095ad...
2026-09-07 17:43
Upload SBOM
Service (optional)
(auto-detect from SBOM)
Version (optional)
(auto-detect from SBOM)
SBOM File (CycloneDX/SPDX JSON)
Browse...
No file selected.
Upload
Cancel
Vulnerabilities
CVE
Severity
CVSS
EPSS
Library
Fixed version
Service
CVE-2026-5450
CRITICAL
9.8
0.50%
libc6 2.41-12+deb13u3
-
rabbitmq
CVE-2026-40469
CRITICAL
9.1
0.35%
gawk 1:5.2.1-2+b1
-
rabbitmq
CVE-2026-40468
CRITICAL
9.1
0.20%
gawk 1:5.2.1-2+b1
-
rabbitmq
GHSA-vp52-pcj8-j9qc
HIGH
8.7
0.41%
google.golang.org/grpc v1.83.0
1.83.1
app
v1.0.0 · AGPL v3

Dashboard
Projects
SBOMs
Vulnerabilities
Settings

Vulnerabilities

Search CVE...

Active | All Severities | All Projects | All Services | Clear filters

CVE	Severity	CVSS	EPSS	Library	Fixed version	Projects	Service	Source	Published at
CVE-2026-5450	CRITICAL	9.8			-	Argus SBOMguard	rabbitmq	grype	-
CVE-2026-40469	CRITICAL	9.1			-	Argus SBOMguard	rabbitmq	grype	-
CVE-2026-40468	CRITICAL	9.1			-	Argus SBOMguard	rabbitmq	grype	-
GHSA-vp52-pcj8-j9qc	HIGH	8.7			1.83.1	Argus SBOMguard	proxy app	grype	2026-09-02
CVE-2026-85091	HIGH	8.3			-	Argus SBOMguard	rabbitmq	grype	-
CVE-2026-86145	HIGH	8.2			-	Argus SBOMguard	rabbitmq	grype	-
CVE-2025-69720	HIGH	7.8			-	Argus SBOMguard	rabbitmq	grype	-
GO-2026-4887	HIGH	7.8			-	Argus SBOMguard	app	grype	-
CVE-2026-5928	HIGH	7.5			-	Argus SBOMguard	rabbitmq	grype	-
CVE-2026-40467	HIGH	7.5			-	Argus SBOMguard	rabbitmq	grype	-
GO-2026-6354	HIGH	7.5	0.32%	golang.org/x/crypto v0.52.0, golang.org/x/crypto …	0.56.0	Argus SBOMguard	proxy app	grype	2026-09-02
GO-2026-6355	HIGH	7.5	0.38%	golang.org/x/crypto v0.52.0, golang.org/x/crypto …	0.56.0	Argus SBOMguard	proxy app	grype	2026-09-02
GO-2026-6303	HIGH	7.5	0.33%	golang.org/x/crypto v0.52.0	0.55.0	Argus SBOMguard	proxy	grype	2026-08-28
CVE-2026-40553	HIGH	7.5	0.29%	gawk 1:5.2.1-2+b1	-	Argus SBOMguard	rabbitmq	grype	-
CVE-2026-5435	HIGH	7.3	0.24%	libc6 2.41-12+deb13u3	-	Argus SBOMguard	rabbitmq	grype	-

CVE-2026-40469 CRITICAL

Library
`gawk 1:5.2.1-2+b1`

CVSS Score
9.1

CVSS Vector
`CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:H/A:H`

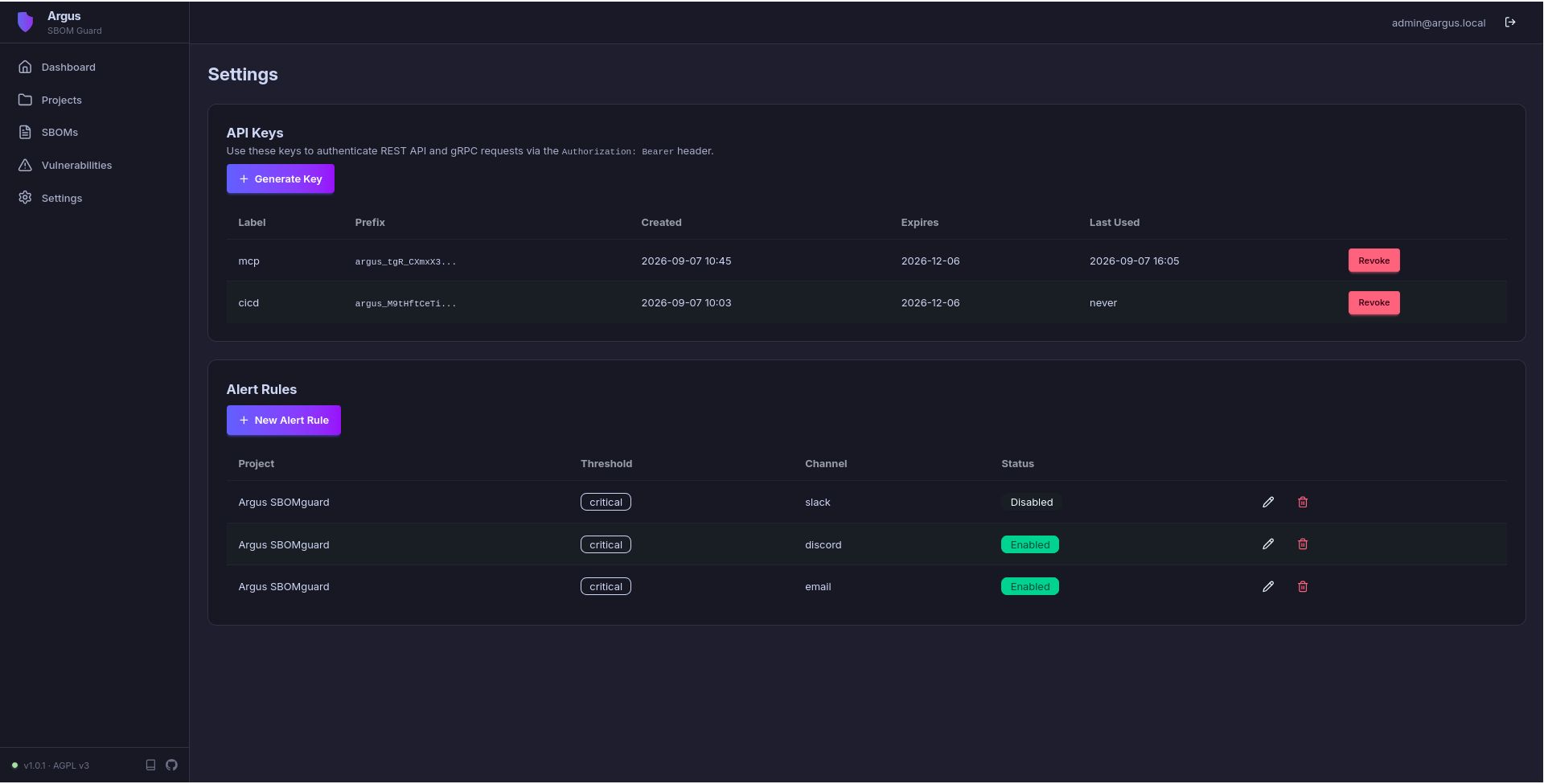
EPSS
0.35% · percentile 28.5

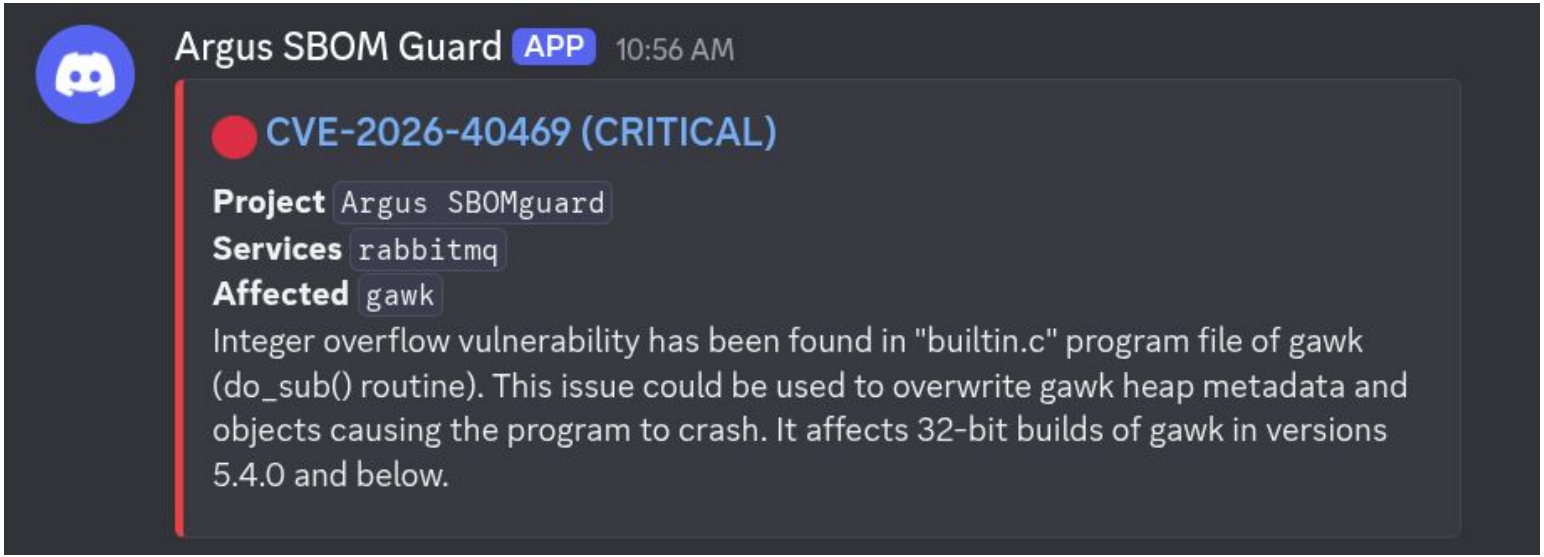
Description
Integer overflow vulnerability has been found in "builtin.c" program file of gawk (do_sub() routine). This issue could be used to overwrite gawk heap metadata and objects causing the program to crash. It affects 32-bit builds of gawk in versions 5.4.0 and below.

View Advisory | Close

Accepting marks this vulnerability as "won't fix". It is excluded from the active list, dashboard counts, snapshots and alerts, and can be reverted later from the Accepted view.

Accept


Argus
SBOM Guard
admin@argus.local
Dashboard
Projects
SBOMs
Vulnerabilities
Settings
Settings
API Keys
Use these keys to authenticate REST API and gRPC requests via the Authorization: Bearer header.
+ Generate Key
Label
Prefix
Created
Expires
Last Used
mcp
argus_tgR_CXmxX3...
2026-09-07 10:45
2026-12-06
2026-09-07 16:05
Revoke
cicd
argus_M9tHftCeTi...
2026-09-07 10:03
2026-12-06
never
Revoke
Alert Rules
+ New Alert Rule
Project
Threshold
Channel
Status
Argus SBOMguard
critical
slack
Disabled
Argus SBOMguard
critical
discord
Enabled
Argus SBOMguard
critical
email
Enabled
v1.0.1 · AGPL v3


Argus SBOM Guard APP 10:56 AM
CVE-2026-40469 (CRITICAL)
Project Argus SBOMguard
Services rabbitmq
Affected gawk
Integer overflow vulnerability has been found in "builtin.c" program file of gawk (do_sub() routine). This issue could be used to overwrite gawk heap metadata and objects causing the program to crash. It affects 32-bit builds of gawk in versions 5.4.0 and below.

Argus SBOM Guard - Cronaca di un side project

```
# MCP Server connection (read only)
```

```
# opencode.json
{
  ...
  "mcp": {
    "argus-sbomguard": {
      "type": "remote",
      "url": "${ARGUS_URL}/api/v1/mcp",
      "oauth": false,
      "headers": {
        "Authorization": "Bearer ${ARGUS_API_KEY}"
      }
    }
  }
}
```

https://trottomv.github.io/argus-sbomguard/latest/api/agents


YEAH, WE IDENTIFIED AND
ASSESSED THAT RISK
WE CHOSE TO ACCEPT IT

Considerazioni Finali 🤔...

Argus SBOM Guard - Cronaca di un side project

```
# …avevamo davvero bisogno di un ennesimo tool open source?!
```

- **nato per la pura voglia di costruire qualcosa** e per il piacere di sporcarsi le mani
- **zero strategia di mercato**
- **open source** (senza licenze e funzionalità enterprise)
- **self hostabile** senza la necessità di mettere in piedi mezzo datacenter
- **prima versione stabile** rilasciata in poco più di un mese
- **spesa di ~30$ di token** a consumo di “deepcoso”

https://github.com/trottomv/argus-sbomguard/

Argus SBOM Guard - Cronaca di un side project

```
# …avevamo davvero bisogno di un ennesimo tool open source?!
```

Call to Action

- Early Adopters o Beta Testers
- Contributions



https://github.com/trottomv/argus-sbomguard/

Quindi... serviva davvero?

Fatemi sapere cosa ne pensate!



/trottomv/argus-sbomguard/



/matteovitali



https://fosstodon.org/@trotto

https://trottomv.me